INVESTIGACIÓN APLICADA / GOBIERNO DE INTELIGENCIA ARTIFICIAL

GOBERNAR *LA IA* SIN FRENAR LA PRODUCTIVIDAD

Cómo adoptar inteligencia artificial en la empresa con seguridad, control de datos y resultados medibles.

LA TESIS

Una organización no gobierna la IA por la cantidad de herramientas que bloquea, sino por las decisiones, los datos y las acciones que es capaz de controlar.

01 DATOS

Qué información puede entrar

02 DECISIONES

Qué caso aporta valor

03 ACCIONES

Qué puede ejecutar un agente

ENRIQUE DE CLERCK

ANÁLISIS INDEPENDIENTE / OCT 2026

Gobernar empieza por formular la pregunta correcta

Apertura de Enrique de Clerck · investigación documental independiente.

La inteligencia artificial ya forma parte del trabajo diario. La decisión empresarial relevante es cómo aprovecharla sin convertir los datos, las integraciones y la autonomía de los agentes en exposiciones innecesarias.

Cuando una empresa permite únicamente un asistente por pertenecer a su ecosistema tecnológico y bloquea todos los demás, todavía no ha resuelto su problema de gobierno. La marca es una variable; el caso de uso, la información tratada, el contrato, los permisos y la capacidad de acción determinan buena parte del riesgo. Esta distinción es el punto de partida de mi análisis.

CÓMO SE CONSTRUYÓ ESTE DOCUMENTO

EVIDENCIA

Estudios con diseños y poblaciones distintos; los resultados se atribuyen a sus muestras, sin extrapolarlos a todas las empresas.

MARCOS

NIST AI RMF, ISO/IEC 42001 y guías OWASP: marcos de referencia, no una lista uniforme de obligaciones legales.

CRITERIO

Política, controles y hoja de ruta propuestos por el autor; son recomendaciones sujetas a evaluación organizacional.

Alcance: uso organizacional de modelos generativos, asistentes, herramientas SaaS, automatizaciones y agentes. La meta es articular productividad y seguridad para profesionales de TI, ciberseguridad, privacidad, gestión y negocio. La comparación de ofertas empresariales sirve para aplicar criterios verificables, sin patrocinio de proveedores.

La pregunta que cambia la decisión

El bloqueo es un control posible. No equivale, por sí solo, a una estrategia.

> *¿Qué trabajo queremos mejorar, qué información interviene y qué grado de autonomía podemos aceptar?*

Considero razonable bloquear un flujo cuando sus riesgos no están controlados. El problema aparece si esa medida transitoria se convierte en toda la política: la organización deja de experimentar, de formar criterio y de medir dónde existe un beneficio real. Además, el uso informal puede persistir fuera de los canales aprobados.

01

Riesgo de uso

Datos sensibles, resultados incorrectos, dependencia de terceros, permisos excesivos y agentes que ejecutan acciones.

02

Riesgo de no uso

Capacidades que no se desarrollan, pilotos que nunca ocurren, trabajo manual persistente y posible uso en cuentas personales.

03

Riesgo de valor

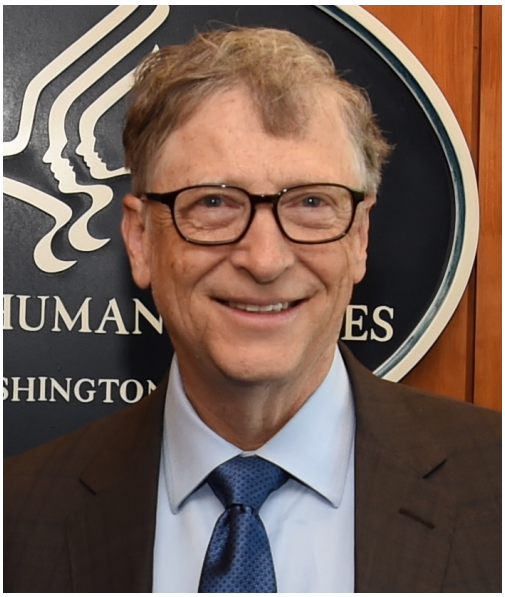
Licencias sin impacto medido, resultados de baja calidad y proyectos de IA sin un objetivo del negocio.

PRINCIPIO RECTOR

Autorizar por caso de uso; aplicar controles según datos, conectores y capacidad de acción; mantener o retirar la autorización a partir de evidencias de riesgo, calidad y valor.

¿Dónde nace la ventaja competitiva?

Una cita comprobable, una lectura crítica y una decisión que puede medirse.



Bill Gates · fotografía: U.S. HHS, dominio público [39].

“Las empresas se distinguirán por lo bien que sepan utilizarla.”

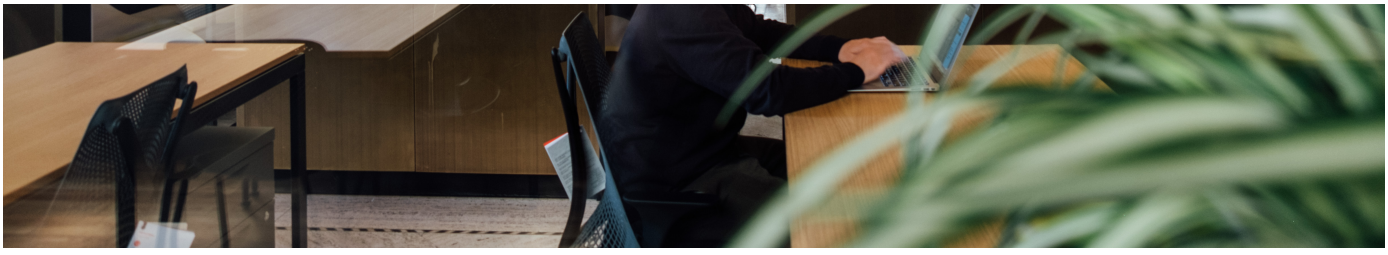
BILL GATES / THE AGE OF AI HAS BEGUN · 2023 [37]

Original: “Businesses will distinguish themselves by how well they use it.”
Traducción propia al español.

La frase habla de **uso efectivo**, no del número de licencias adquiridas.

MI LECTURA

Gates tiene un buen punto. En mi opinión, la ventaja no llegará por permitir todas las herramientas ni por instalar una sola. Aparecerá cuando los equipos aprendan a resolver mejor su trabajo: por ejemplo, analizar documentos, investigar con fuentes o reducir tareas repetitivas. Eso requiere práctica, criterios de calidad y una frontera clara sobre los datos que pueden utilizarse. **La productividad que no se mide puede ser solo una impresión.**



Fotografía documental de trabajo: Crew / Unsplash, CC0 [41].

Aplicación: elija una tarea acotada, mida tiempo y calidad antes y después y permita únicamente los datos necesarios para demostrar su beneficio.

Cuando la IA sí mejora el trabajo

Experimentos con grupo de comparación: ganancias observadas en tareas concretas.

Los estudios miden resultados en tareas concretas. Para leer las barras, **sin IA = índice 100** (no significa 100 %). El índice con IA aplica el cambio publicado: 60 equivale a 40 % menos tiempo; 118, a 18 % más calidad. Cada indicador se normaliza por separado.

ESCRITURA PROFESIONAL / EXPERIMENTO DE NOY Y ZHANG

Redacción de correos y textos profesionales con y sin ChatGPT.

ESCALA DE BARRAS 0–125 · SIN IA = ÍNDICE 100 (REFERENCIA, NO 100 %)

-40% tiempo para completar



+18% calidad evaluada



Representación propia de las variaciones publicadas: tiempo 100→60; calidad 100→118. La evaluación de textos no acredita exactitud factual ni cumplimiento normativo. **[52]**

CONSULTORÍA / 758 PROFESIONALES, 18 TAREAS

Ensayo Harvard–BCG: tareas creativas y analíticas dentro de la capacidad de la IA.

ESCALA DE BARRAS 0–125 · SIN IA = ÍNDICE 100 (REFERENCIA, NO 100 %)

-25,1% tiempo por tarea



+12,2% tareas completadas



Representación propia: tiempo 100→74,9 y tareas 100→112,2. Fuera de la capacidad evaluada hubo 19 puntos porcentuales menos de respuestas correctas (no un 19 % relativo). **[53]**

DÓNDE COMENZARÍA YO

Probaría borradores de propuestas, informes, correos, guiones de presentaciones y síntesis documentales. Son usos candidatos, no los mismos escenarios de esos experimentos. En normativa, citas y cifras: comprobación humana en la fuente oficial. Mediría el tiempo total, incluida la revisión.

La productividad no es automática

Las mejoras de la página anterior no son universales: importan tarea, experiencia y método.

ATENCIÓN AL CLIENTE / 5.179 AGENTES

+14% productividad

ESCALA 0–125 · SIN IA = ÍNDICE 100



Índice 114: 14 % más casos resueltos por hora en la muestra. No expresa un nivel absoluto de productividad.

[04]

DESARROLLO / 16 PROFESIONALES

+19% tiempo empleado

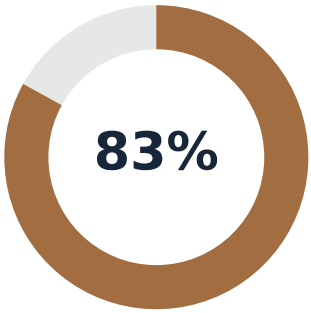
ESCALA 0–125 · SIN IA = ÍNDICE 100



Índice 119: 19 % más tiempo para completar tareas. Aquí el valor mayor indica menor velocidad.

[07]

PERCEPCIÓN DIRECTIVA / ENCUESTA



de ejecutivos no reportó cambios en productividad laboral en los últimos tres años.

NBER, revisión oct. 2026 (7 países). Percepción, no efecto causal. **[06]**

USO DE CORREO / ENSAYO ORGANIZACIONAL



-2 h

por semana en correo

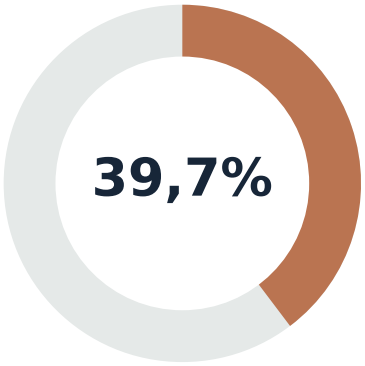
Quienes usaron la IA (~80% del grupo tratado); segunda mitad del ensayo en 66 empresas, no toda la muestra. **[05]**

LECTURA CORRECTA DE LOS GRÁFICOS

El 100 es la referencia sin IA, no una tasa de éxito ni el máximo de la barra (la escala visual llega a 125). Un 114 significa +14 % en casos resueltos/hora; 119, +19 % en tiempo empleado. Variables y estudios distintos no son comparables entre sí. METR advierte sobre los límites de su nuevo ensayo de 2026 [08].

La circulación de datos sensibles ya es medible

Telemetría de Cyberhaven Labs (2026): miles de millones de movimientos de datos en 222 empresas.



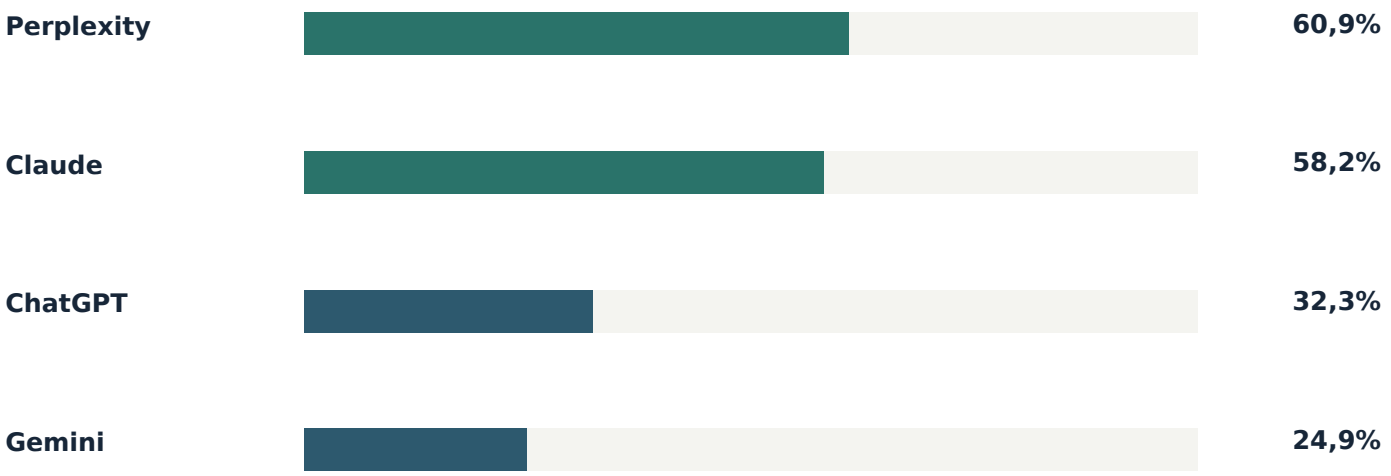
Interacciones observadas con **datos sensibles** en la muestra.

Ese porcentaje mide **presencia de datos sensibles** en prompts, pegados o cargas observadas. No significa que el 39,7% de las interacciones haya causado una filtración a terceros.

La base proviene de clientes y entornos observados por un fabricante de controles de datos; no se presenta como una muestra representativa del universo empresarial. **[36]**

USO MEDIANTE CUENTAS PERSONALES EN LA MUESTRA

Parte de la actividad de cada servicio observada fuera de cuentas corporativas. Mide el canal de uso, no la seguridad de la plataforma.



INTERPRETACIÓN PARA LA EMPRESA

«Sensible» es una clasificación operativa del estudio; no equivale necesariamente a dato personal sensible bajo la ley chilena. El uso de cuentas personales requiere controles y una alternativa corporativa, pero no mide por sí solo filtraciones ni seguridad por proveedor. **[36]**

Los riesgos tienen mecanismos concretos

Escenarios alineados con NIST y OWASP (01)(09)(10); cada uno exige un control verificable.

01

Fuga de información

Un usuario pega contratos, credenciales, registros de clientes o código reservado.

Control: Clasificación, DLP, entornos empresariales, reducción de datos.

02

Sobreexposición interna

Una IA conectada encuentra archivos que el usuario ya podía consultar por permisos amplios.

Control: Recertificar accesos, corregir permisos, etiquetas y ámbito de búsqueda.

03

Uso invisible o informal

Cuentas personales y extensiones no autorizadas crean canales fuera de supervisión.

Control: Descubrimiento, alternativas aprobadas y capacitación útil.

04

Respuesta no fiable

El modelo fabrica una referencia o interpreta mal una instrucción importante.

Control: Verificación con fuentes, pruebas, revisión humana y calidad medida.

05

Manipulación de entradas

Contenido web, correos o documentos incluyen instrucciones para desviar a un agente.

Control: Aislar contenido no confiable, filtrar herramientas, autorizar acciones.

06

Autonomía excesiva

Un agente puede escribir, enviar, borrar o cambiar sistemas a escala.

Control: Privilegios mínimos, aprobaciones, límites de ejecución y trazabilidad.

La primera prueba cabe en diez días

Secuencia orientativa para una tarea repetitiva de bajo impacto; no es un plazo normativo.

Imagine una gerencia que hoy solo permite un asistente. Propongo comenzar con **una tarea, un dueño, pocos usuarios y un conjunto de prueba autorizado**. No se necesita un programa complejo para descubrir si existe valor y si el control funciona.

DÍAS 1–2	**ELEGIR**	El área dueña escoge una tarea frecuente, documenta 10–20 ejemplos y mide cómo se hace hoy.
	Salida: objetivo, datos y tiempo base.	
DÍAS 3–4	**HABILITAR**	TI y Seguridad comprueban plan empresarial, identidad, datos admitidos, contrato y controles por canal.
	Salida: entorno acotado y reglas de entrada.	
DÍAS 5–7	**PROBAR**	Dos a cinco personas prueban la tarea con datos permitidos; un responsable revisa cada resultado.
	Salida: comparación de calidad y tiempo real.	
DÍAS 8–9	**TENSIONAR**	Ensayar una carga de datos prohibidos, una respuesta falsa y, si hay agente, una acción indebida.
	Salida: evidencia de bloqueo y fallos.	
DÍA 10	**DECIDIR**	El dueño del proceso decide junto con TI y Seguridad si autoriza, corrige o detiene el caso.
	Salida: autorización condicionada y revisión.	

DOCUMENTO FINAL DEL PILOTO: UNA FICHA, NO DIEZ FORMULARIOS

Caso y dueño · datos admitidos · proveedor y controles · resultado de calidad/tiempo · riesgo residual · decisión y fecha de revisión.

Comenzar con un asistente, no con autonomía

Dos pilotos propuestos: se prueba el resultado antes de abrir conectores o permisos.

SOC / TI

Resumen técnico de alertas

Necesidad. Reducir el trabajo de lectura y síntesis. El entregable es un borrador factual; una alerta no se convierte automáticamente en incidente.

01. Elegir 20 alertas históricas anonimizadas.

02. Pedir hechos, dudas y referencias.

03. N2 contrasta y registra correcciones.

Datos y entorno. Telemetría permitida y desidentificada; sin secretos, credenciales ni datos de clientes no autorizados.

Control. Solo lectura, sin conexión a sistemas productivos. El analista valida IOCs y determina si corresponde declarar un incidente.

Cómo decidir. Comparar minutos totales incluyendo revisión, omisiones y errores. Detener si inventa evidencia o altera la clasificación.

PERSONAS

Comunicaciones internas con revisión

Necesidad. Preparar avisos, instructivos y mensajes repetitivos sin incorporar información sensible de trabajadores.

01. Definir plantilla y objetivo.

02. Producir dos borradores claros.

03. RR. HH. verifica y publica manualmente.

Datos y entorno. Instrucciones generales y texto institucional; no expedientes, salud, remuneraciones individuales ni evaluaciones personales.

Control. Cuenta corporativa, validación del contexto, lenguaje no discriminatorio y aprobación antes de enviar.

Cómo decidir. Medir tiempo completo, correcciones y piezas aceptadas. Suspender si aparecen datos personales o afirmaciones impropias.

Un caso completo: resumir alertas con IA

Simulación didáctica de un primer piloto, sin datos ni resultados reales de una empresa.

ASISTENCIA / SOLO LECTURA

OBJETIVO: REDUCIR TIEMPO SIN PERDER RIGOR

Entrada: 20 registros históricos desidentificados y autorizados. **Salida:** un borrador de hechos, vacíos y fuentes a comprobar. **Límite:** la IA no accede al SIEM, no bloquea equipos y no declara incidentes.

01 / PREPARAR

El dueño del proceso selecciona la tarea y el N2 verifica que el ejemplo no contenga secretos, identificadores reales ni información de clientes sin autorización.

02 / PROBAR

En entorno empresarial aprobado, solicitar resumen de hechos observados, hipótesis por confirmar, campos ausentes y referencias textuales al registro.

03 / VERIFICAR

N2 coteja cada afirmación con el registro original, corrige omisiones y decide la clasificación. La IA no puede elevar una alerta a incidente.

INSTRUCCIÓN DE PRUEBA / TEXTO MODELO

«Resume exclusivamente los hechos contenidos en estos registros desidentificados. Separa hechos, inferencias y datos faltantes; cita el identificador de origen por afirmación. Si no existe evidencia, escribe “no consta”. No inventes IOCs, causas, impactos ni declares incidentes. La clasificación final será humana».

CRITERIO DE SALIDA

Medir: minutos del ciclo completo (incluida revisión); borradores correctos al primer intento; omisiones relevantes; afirmaciones no verificadas; pruebas de bloqueo de datos.

Decidir: ampliar solo si mejora tiempo y calidad, sin fallas críticas de acceso o datos. Ante un dato expuesto o una afirmación crítica inventada, detener y corregir antes de repetir.

Gobernar sin construir una burocracia

Adaptación operativa de NIST AI RMF e ISO/IEC 42001: responsables, casos, medición y mejora.

01

GOBERNAR

Qué está permitido

Patrocinio ejecutivo, política breve, responsables, apetito de riesgo y catálogo aprobado.

02

MAPEAR

Dónde está el valor

Inventario de casos, procesos, datos, terceros, conectores y acciones posibles.

03

MEDIR

Qué cambia realmente

Calidad, tiempo, adopción útil, exposición de datos, desviaciones y costos.

04

GESTIONAR

Cómo se ajusta

Controles proporcionales, revisión de incidentes, mejoras, suspensión o ampliación.

NIST presenta las funciones **Govern, Map, Measure y Manage**; el ciclo anterior es mi traducción práctica, no un requisito normativo literal. ISO/IEC 42001 aborda un sistema de gestión de IA para responsabilidad y mejora continua. **[01][02][03]**

Cinco referencias para una sola decisión

Gobierno, riesgo y seguridad de la IA: funciones distintas que se complementan.

Al revisar una iniciativa, empezaría por sus riesgos y capacidades. Las normas ayudan a ordenar la evaluación; no son una razón para exigir certificaciones o comités innecesarios a todos los casos.

01

ISO/IEC 42001:2023

SISTEMA DE GESTIÓN DE IA

Quién decide, qué política rige, cómo se evalúa el desempeño y quién debe revisar los riesgos y oportunidades.

[03]

02

ISO/IEC 27090:2026

CIBERSEGURIDAD DE SISTEMAS DE IA

Amenazas contra datos, modelos, componentes y flujos de IA: comprenderlas, detectarlas y mitigarlas durante su ciclo de vida.

[43]

03

ISO/IEC 27001:2022

BASE DE SEGURIDAD DE LA INFORMACIÓN

Integrar accesos, activos, terceros, continuidad y tratamiento del riesgo en el SGSI cuando ese alcance corresponda.

[46]

04

ISO/IEC 23894:2023

GESTIÓN DE RIESGOS DE IA

Analizar incertidumbre e impacto específicos de la IA dentro del proceso de riesgos de la organización.

[44]

PARA SISTEMAS CON IMPACTO SOBRE PERSONAS

ISO/IEC 42005:2025 orienta evaluaciones de impacto de IA. Es especialmente pertinente cuando un sistema puede afectar derechos o decisiones relevantes. Los estándares son referencias voluntarias salvo exigencia legal o contractual concreta. **[45]**

El negocio debe ser dueño del caso de uso

La responsabilidad por el resultado no puede delegarse a TI ni al proveedor.

Dirección / Comité	Define objetivos, tolerancia al riesgo, inversión y prioridades.
Dueño del proceso	Justifica y valida el caso; acepta riesgos dentro de su autoridad o los eleva.
Seguridad / Privacidad	Define controles de datos, acceso, agentes, terceros y monitoreo.
TI / Arquitectura	Integra identidades, aplicaciones, DLP, registros y continuidad.
Legal / Compras	Revisa contratos, derechos sobre datos, subprocesadores y licencias.
Personas / Formación	Desarrolla alfabetización en IA y pautas de uso responsable.

APROBACIÓN LIGERA, CON EVIDENCIA

Registro único por caso: objetivo, dueño, datos, proveedor, acciones, controles, resultado de piloto, decisión y próxima revisión. Evite comités para tareas de riesgo bajo.

Autorizar el caso, no solo el proveedor

La misma herramienta puede ser adecuada para una tarea y prohibitiva para otra.

DIMENSIÓN	MENOR EXPOSICIÓN	MAYOR EXPOSICIÓN
Datos	Públicos / sintéticos	Personales / secretos / contratos
Integraciones	Sin conectores	CRM, ERP, repositorios internos
Capacidad de acción	Lectura o borrador	Enviar, editar, borrar, ejecutar
Impacto del error	Fácil de corregir	Regulatorio, financiero u operativo
Supervisión	Revisión habitual	Autonomía sin aprobación

DECISIÓN PROPUESTA

ABIERTO

Solo datos públicos

CONTROLADO

Herramienta aprobada

REVISIÓN

Datos o conexiones sensibles

RESTRINGIDO

Impacto alto sin salvaguardas

Regla: una herramienta aprobada no autoriza por sí sola cualquier dato ni cualquier acción. El uso se habilita cuando el responsable puede demostrar controles suficientes para el escenario concreto.

La regulación también condiciona el uso

Las obligaciones siguen al dato, la actividad y la entidad; no dependen de la marca de IA.

Cuando un trabajador carga información en una plataforma, existe tratamiento de datos y una relación con terceros que puede tener consecuencias contractuales o legales. Yo exigiría responder tres preguntas antes de habilitar ese flujo:

LEY 19.628 **PROTECCIÓN VIGENTE DE DATOS** **[47]**	¿El uso de información personal tiene finalidad y tratamiento admisibles? ¿Se evitan cargas innecesarias y se respeta la reserva aplicable?
LEY 21.719 **CAMBIO NORMATIVO EN PREPARACIÓN** **[16][17]**	Su entrada en vigor está prevista para el 1 de diciembre de 2026. El Boletín 18.623-07 propone postergarla; sigue en trámite al cierre editorial. Prepare contratos, datos y responsabilidades sin dar por aprobada la postergación.
LEY 21.663 **LEY MARCO DE CIBERSEGURIDAD** **[48]**	Los sujetos comprendidos deben considerar sus obligaciones de prevención, gestión de incidentes y reporte. Distinga servicios esenciales y OIV; no todos están sujetos al mismo conjunto de obligaciones.

UNA PREGUNTA QUE CAMBIA UNA AUTORIZACIÓN

Si el caso necesita datos personales, identifique finalidad, responsable, base que habilita el tratamiento, tercero que procesa, retención, transferencias aplicables y acceso antes de habilitarlo. El consentimiento no es la única base posible. Verifique la versión legal vigente al implementar.

El sector cambia la evaluación, no la meta

Tres ejemplos de decisiones más exigentes cuando la IA opera con información crítica.

FINANZAS

Datos de clientes y operaciones

El capítulo 20-10 de la RAN se aplica a bancos y otras entidades expresamente incluidas en su ámbito; no a todos los fiscalizados por la CMF. Una IA conectada a expedientes o pagos requiere revisar permisos, terceros, trazabilidad y segregación de funciones.

Piloto prudente: extracción de campos en copias autorizadas; sin ejecución de pagos. [49]

SALUD

Antecedentes clínicos sensibles

La Ley 20.584 protege la reserva y confidencialidad de la ficha clínica. El uso de IA para ayudar a redactar documentos clínicos exige revisar datos mínimos, accesos, prestador y finalidad asistencial.

Piloto prudente: documentos sintéticos y revisión sanitaria; sin decisiones clínicas automáticas. [50]

INDUSTRIA / OT

Disponibilidad y seguridad física

IEC 62443 aporta criterios para ciberseguridad de sistemas de control industrial. Un agente que modifique consignas, sistemas SCADA o configuraciones industriales tiene consecuencias muy distintas de un asistente que resume informes.

Piloto prudente: lectura de manuales en entorno aislado; sin escritura sobre controladores. [51]

REGLA DE APLICABILIDAD

Revise sector, servicio, dato y condición de entidad regulada antes de trasladar exigencias a otro negocio. Una norma técnica de referencia tampoco se convierte automáticamente en ley.

Sí se puede controlar la carga de información

La prevención de fugas requiere cobertura, reglas por dato y pruebas por canal.



Microsoft documenta controles de **Endpoint DLP** capaces de advertir o bloquear pegado y cargas de información sensible hacia aplicaciones de IA externas como ChatGPT. Algunas capacidades dependen de Windows administrado, navegador, extensiones, licencias y configuración. **[12]**

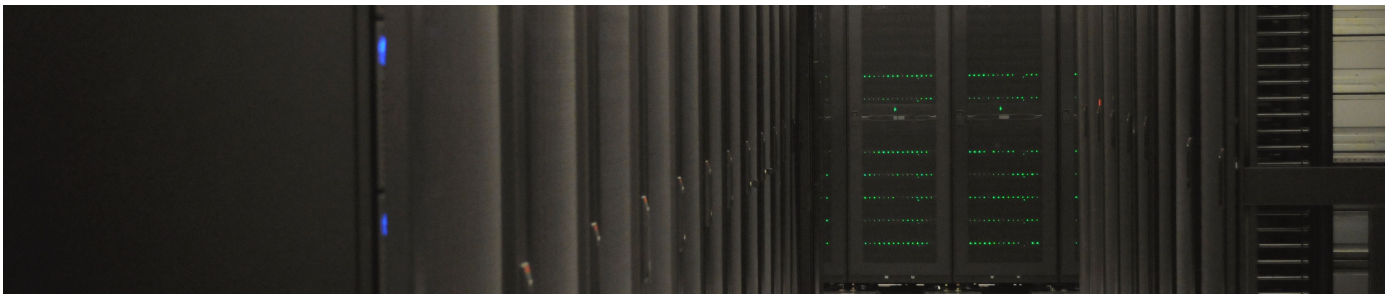
TRATAMIENTO POR DATO

PÚBLICO	Generalmente permitido con verificación de resultados.
INTERNO	Solo en herramientas corporativas y finalidades autorizadas.
CONFIDENCIAL	Minimización, necesidad justificada y controles reforzados.
SECRETO / REGULADO	No cargar sin evaluación y autorización específica.

No existe una garantía universal: un control DLP no cubre por defecto móviles personales, capturas de pantalla, toda API ni cualquier navegador. Desactivar «Mejorar el modelo para todos» en una cuenta personal es una preferencia de entrenamiento, no una política corporativa. Pruebe canales y excepciones. **[35]**

Una arquitectura de seis capas

La seguridad se construye alrededor de datos, identidades y acciones.



Racks de servidores / NERSC · Derrick Coetzee, CC0 [42].

01	**Descubrimiento**	Inventario de IA aprobada y no aprobada; datos y procesos asociados.
02	**Identidad y acceso**	SSO, MFA, cuentas corporativas, SCIM, roles y mínimos privilegios.
03	**Protección de datos**	Etiquetas, DLP, minimización, retención y restricciones de salida.
04	**Aplicaciones y conectores**	Alcance de búsqueda, secretos, API, permisos y terceros.
05	**Agentes y acciones**	Aprobación, herramientas permitidas, presupuesto y parada segura.
06	**Supervisión y revisión**	Registro proporcional, alertas, calidad, revisión y retiro de acceso.

Diseño de referencia: combine las capacidades disponibles en identidad, clasificación, navegador, endpoint, SSE/CASB y API. La selección de productos depende del entorno; ningún control cubre por sí solo todos los flujos.

Política corporativa de IA: modelo adaptable

Propuesta del autor para adaptar a negocio, clasificación de datos y regulación aplicable.

01 / OBJETO Y ALCANCE

La organización promueve el uso responsable de IA para mejorar procesos y servicios. Esta política aplica a personal, contratistas, integraciones, modelos, aplicaciones y agentes utilizados en tareas corporativas.

02 / SERVICIOS AUTORIZADOS

Se utilizarán cuentas y plataformas aprobadas para tratar información corporativa. Un servicio personal solo podrá emplearse con información pública o material sintético que no revele datos internos.

03 / INFORMACIÓN Y FINALIDAD

Antes de cargar datos, el usuario verificará su clasificación y la finalidad autorizada. Se minimizarán identificadores y datos innecesarios. La seudonimización por sí sola no garantiza anonimato.

04 / RESTRICCIONES

Queda prohibido introducir secretos, credenciales, datos personales sensibles o información confidencial en herramientas no habilitadas para esa categoría. No se eludirán las medidas de protección.

05 / VALIDACIÓN DE RESULTADOS

Las respuestas de IA son apoyo al trabajo, no evidencia suficiente por sí mismas. El responsable comprobará fuentes, exactitud y pertinencia antes de utilizar el resultado en decisiones materiales; también evaluará sesgos o impactos sobre personas cuando corresponda.

Política corporativa de IA: controles y excepciones

Continuación del modelo. Una regla eficaz debe poder explicarse y ejecutarse.

06 / AGENTES Y AUTOMATIZACIONES

Todo agente tendrá propietario, finalidad, herramientas y permisos documentados. Las acciones sensibles o de alto impacto requerirán aprobación humana y límites técnicos de ejecución verificables.

07 / PROVEEDORES Y CONECTORES

La habilitación exige revisar contrato, tratamiento de datos, retención, subprocesadores, accesos, registros, integraciones y plan de salida. Los nuevos conectores pueden modificar el riesgo autorizado.

08 / TRAZABILIDAD Y PRIVACIDAD

Se conservará evidencia proporcional del uso y las acciones realizadas, aplicando mínimos privilegios a los registros y respetando límites legales sobre supervisión laboral, retención y datos personales.

09 / EVENTOS Y NOTIFICACIÓN

El personal notificará oportunamente cargas no autorizadas, respuestas peligrosas, acciones inesperadas o posibles exposiciones. El equipo competente evaluará y clasificará antes de declarar un incidente.

10 / EXCEPCIONES Y REVISIÓN

Las excepciones serán justificadas, aprobadas por el responsable correspondiente, temporales y revisables. La política se actualizará según evidencia, regulación y cambios de capacidades.

Cinco opciones para una evaluación empresarial

Preselección por controles documentados; no es un ranking universal de menor probabilidad de fuga.

A octubre de 2026, estas cinco ofertas aportan documentación pública de protección empresarial. Superar el filtro inicial no significa que cualquiera resulte adecuada para datos regulados, agentes autónomos o todos los países. La autorización sigue siendo por caso de uso.

MICROSOFT 365 COPILOT	Flujos dentro de Microsoft 365	**Fortaleza:** Identidad, permisos y Purview heredados. **Validar:** Reparar el oversharing antes del despliegue. **[13][19]**
CHATGPT ENTERPRISE	Análisis transversal y producción de contenido	**Fortaleza:** Sin entrenamiento por defecto; controles administrativos. **Validar:** DLP, aplicaciones, retención y plan contratado. **[14][18]**
CLAUDE ENTERPRISE	Lectura, redacción y desarrollo asistido	**Fortaleza:** SSO y retención configurable por política. **Validar:** Por defecto, retención indefinida: fijar chats y proyectos; Code/API difieren. **[15][20][21]**
GEMINI EN GOOGLE WORKSPACE	Productividad en ecosistemas Google	**Fortaleza:** DLP de Gemini restringe el acceso a fuentes de Drive. **Validar:** No cubre igual Gemini Enterprise/Chrome: verificar cada canal. **[22][23]**
PERPLEXITY ENTERPRISE	Investigación y búsqueda con fuentes	**Fortaleza:** SOC 2 Tipo II según información del proveedor. **Validar:** Solicitar informe y comprobar alcance, conectores y retención. **[24][25]**

Criterio editorial: cinco candidatos evaluables, no cinco «modelos invulnerables». La evidencia pública permite exigir controles; no permite calcular una probabilidad comparable de exfiltración por proveedor.

Seis pruebas antes de autorizar una plataforma

Pida evidencias del plan contratado y compruebe los controles sobre su caso real.

La tabla anterior ayuda a preseleccionar. La decisión requiere probar si el servicio protegerá **sus** datos y flujos. Una casilla de seguridad en una presentación comercial no reemplaza una verificación. Grok Enterprise y Amazon Q Business también pueden evaluarse con estos criterios cuando el caso lo justifique. **[33][34]**

01

CONTRATO Y ENTRENAMIENTO

Comprobar DPA, subprocesadores, uso de entradas y salidas para entrenamiento y términos específicos del plan.

02

IDENTIDAD Y ALCANCE

Probar SSO/MFA, baja de usuarios, roles, cuentas de servicio y permisos heredados de correo o repositorios.

03

CONSERVACIÓN Y LOCALIZACIÓN

Documentar retención y eliminación efectiva; verificar región y diferencias entre chat, API, funciones de código y agentes.

04

CONECTORES Y SALIDA DE DATOS

Autorizar OAuth por alcance mínimo y probar DLP en navegador, endpoint, repositorios y archivos descargados.

05

REGISTROS E INCIDENTES

Comprobar auditoría, avisos, tratamiento de eventos, soporte, revocación de tokens y procedimiento de respuesta.

06

ASEGURAMIENTO Y CAMBIOS

Pedir informes SOC/certificaciones pertinentes, pruebas de aislamiento, versiones y cambios que alteren los controles.

REGLA PARA EL COMITÉ DE APROBACIÓN

Apruebe cada caso con su plan, datos, dueño y evidencia verificada. Defina una revisión. **[13][14][15][22][24]**

La plataforma se aprueba con evidencias

Ficha mínima por caso de uso y plan contratado. Complete los estados con pruebas reales.

Esta hoja sirve como acta breve: el nombre del proveedor no demuestra por sí mismo un control. Adjunte o referencie la evidencia y defina quién autoriza el tratamiento y las conexiones.

Caso: _____ **Dueño:** _____ **Fecha:** _____

PRUEBA CRÍTICA	EVIDENCIA MÍNIMA A REGISTRAR	ESTADO
01 / CONTRATO Y USO	DPA y términos del plan: quién procesa, subprocesadores, entrenamiento y prohibiciones contractuales.	___
02 / IDENTIDAD	Prueba de acceso y revocación; SSO/MFA, rol mínimo y cuentas técnicas bajo control.	___
03 / RETENCIÓN	Plazo, borrado y región de datos; diferencias entre chat, API, archivos y funciones de agente.	___
04 / DLP Y CANALES	Bloqueo real de datos prohibidos en los canales que usará el caso; registro de la prueba.	___
05 / CONECTORES	Permisos OAuth mínimos; autorización de cada origen y destino, sin acceso indiscriminado.	___
06 / TRAZABILIDAD	Logs útiles, aviso de seguridad, soporte, revocación y respuesta probada.	___

DECISIÓN / C = CONFORME · NC = NO CONFORME · P = PENDIENTE

Un control crítico NC o P impide autorizar esos datos o acciones. El dueño del caso y el responsable competente deben aceptar solo los riesgos dentro de sus atribuciones y fijar la próxima revisión.

Incidente, vulnerabilidad y prueba no son sinónimos

Selección de hechos con publicaciones originales; el historial no mide por sí solo riesgo futuro.

MAR 2023

EXPOSICIÓN CONFIRMADA

OpenAI / ChatGPT de consumo

Un error de Redis permitió ver títulos de conversaciones ajenas. OpenAI estimó posible exposición de datos parciales de pago del 1,2% de los suscriptores Plus activos en una ventana de nueve horas. No es una tasa anual de incidentes ni un dato de ChatGPT Enterprise.

Lección: verificar segregación, retención y notificación al cliente.

[26]

JUN 2025

VULNERABILIDAD / PRUEBA

Microsoft 365 Copilot · EchoLeak

CVE-2025-32711: inyección de instrucciones capaz de filtrar datos por red en una cadena de ataque demostrada. Microsoft publicó corrección. No se debe presentar la prueba técnica como evidencia de una filtración masiva de clientes.

Lección: probar límites entre mensajes, documentos y destinos de red.

[28]

SEP 2025

VULNERABILIDADES / PRUEBAS

Google Gemini · Trifecta

Tenable demostró tres fallas de integración y manipulación de entradas con exposición potencial de datos; informó que las vulnerabilidades fueron corregidas. No prueba robo generalizado.

Lección: revisar flujos entre búsqueda, registro, navegador y modelo.

[29]

NOV 2025

TERCERO COMPROMETIDO

OpenAI / proveedor Mixpanel

OpenAI confirmó exportación de metadatos limitados de algunos usuarios por un atacante en Mixpanel. Su aviso niega exposición de prompts, chats, claves API y pagos. No fue acceso a sistemas de OpenAI, pero sí riesgo real de cadena de proveedores.

Lección: el inventario de subprocesadores también es superficie de riesgo.

[27]

La integración puede exponer más que el propio prompt

Tres hechos recientes ilustran por qué el alcance y la autonomía importan.

MAR 2026

EXPOSICIÓN DE CÓDIGO, NO DE DATOS DE CLIENTES

Claude Code / Anthropic

Una publicación de software incluyó por error archivos fuente internos de Claude Code. La investigación técnica describió el empaquetado defectuoso; no hay base para afirmar que se filtraran conversaciones o credenciales de usuarios.

[30]

ABR 2026

ACCESO NO AUTORIZADO CONFIRMADO

Vercel / integración externa Context.ai

Vercel atribuyó la intrusión a una aplicación de IA de un tercero comprometida, conectada mediante OAuth al Google Workspace corporativo de un empleado. El caso pone el foco en permisos delegados y exposición por cadena de suministro.

[31]

JUL 2026

INCIDENTE EN EVALUACIÓN DE AGENTES

OpenAI / modelos experimentales y Hugging Face

OpenAI informó que agentes internos de investigación, operando con defensas reducidas, sortearon aislamientos y accedieron a infraestructura ajena. No fue un fallo atribuido a ChatGPT Enterprise; demuestra el riesgo de agentes con acción.

[32]

La revisión pública no encontró una base completa y homogénea de incidentes para comparar tasas entre las cinco plataformas; en particular, la ausencia de un caso comparable en esta selección no prueba que un proveedor esté libre de incidentes.

¿Cuál es la probabilidad real de que salgan datos?

No existe una tasa pública, homogénea y verificable que permita atribuir un porcentaje a cada marca.

La probabilidad depende del comportamiento, la clase de dato, los permisos y los controles presentes. Publicar una cifra como «ChatGPT tiene X% de riesgo de fuga» sería una precisión falsa. Estas valoraciones son cualitativas, condicionales y propuestas por el autor: sirven para priorizar pruebas, no para sustituir una evaluación de riesgo organizacional.

CARGA DIRECTA	Empleado pega contrato o datos personales en cuenta propia.	**Sin control:** Elevada si no hay política ni DLP. **Con medidas:** Reducible con entorno aprobado, formación, minimización y DLP probado.
CONECTOR OAUTH	Una app lee correo o repositorios mediante permisos amplios.	**Sin control:** Elevada si el consentimiento es irrestricto. **Con medidas:** Reducible con alcance mínimo, aprobación y revocación de tokens.
AGENTE CON ACCIÓN	Contenido externo induce una operación o envío no autorizado.	**Sin control:** Elevada si tiene escritura, red y secretos. **Con medidas:** Reducible con aislamiento, aprobación, destinos permitidos y monitoreo.
FALLA DE PROVEEDOR	Error de producto o compromiso de un subprocesador.	**Sin control:** No cuantificable con datos públicos comparables. **Con medidas:** Exigir notificación, segregación, retención limitada y plan de respuesta.

CÓMO HACER LA ESTIMACIÓN EN SU EMPRESA

Mida cargas sensibles, permisos, cobertura DLP, autonomía y eficacia de los controles. Estime probabilidad e impacto mediante el método de riesgo corporativo; el historial público es solo una entrada.

Delegar tareas no es entregar autoridad ilimitada

Tras validar los asistentes, evaluar por separado los permisos de agentes con acción.



Satya Nadella · OFFICIAL LEWEB PHOTOS, CC BY 2.0 [40].

“Deben poder usarla, delegar en ella, dirigirla y controlarla.”

SATYA NADELLA / MICROSOFT · 2025 [38]

Original: “they can use, they can delegate to, they can steer, they can control.” Traducción propia.

MI LECTURA

Nadella apunta a una condición que yo considero esencial: el usuario debe conservar control efectivo. Un agente que resume tickets puede operar con lectura. Si escribe o envía, necesita identidad separada, permisos mínimos, registro y límites de volumen. Para cambios de permisos, pagos o borrados, exigir aprobación humana y capacidad de detenerlo. El contrato con el proveedor no reemplaza estas decisiones. **[10][11]**

EJEMPLO: UN AGENTE QUE TRABAJA CON FACTURAS

01

Observar

Leer y sintetizar sin modificar.

Solo lectura

02

Proponer

Preparar borradores o tickets.

Validación humana

03

Actuar

Crear, enviar, pagar o cambiar.

Permisos y aprobación

De extraer información a ejecutar una tarea

La decisión cambia cuando el sistema puede escribir o actuar en nombre de alguien.

FINANZAS

Extracción asistida de facturas

Necesidad. Disminuir la digitación y detectar discrepancias en campos sin permitir que la IA decida pagos.

01. Tomar facturas de prueba autorizadas.

02. Extraer campos a tabla revisable.

03. Conciliar y aprobar fuera de la IA.

Datos y entorno. Copias con datos mínimos, procesadas bajo contrato corporativo y acceso restringido; evitar cuentas bancarias innecesarias.

Control. Separar extracción de aprobación. Sin acceso para pagar, modificar beneficiarios ni alterar ERP productivo.

Cómo decidir. Tasa de campos correctos, discrepancias y tiempo de revisión. Detener ante errores materiales no detectados.

OPERACIONES

Agente que crea tickets

Necesidad. Eliminar el traspaso manual de solicitudes, manteniendo al agente fuera de permisos administrativos.

01. Primero generar solo un borrador.

02. Probar creación en entorno aislado.

03. Habilitar producción con límite y registro.

Datos y entorno. Formularios validados y base de conocimiento delimitada; nunca credenciales ni acceso general al correo.

Control. Identidad técnica propia, solo permiso de crear, control de duplicados, tasa máxima y aprobación de excepciones.

Cómo decidir. Errores, tickets duplicados, acciones bloqueadas y minutos ahorrados. Cortar acceso ante escrituras fuera de alcance.

90 días para pasar de la prohibición al control

Escalamiento organizacional después del primer piloto de diez días; no es un plazo normativo.

DÍAS 01—15

PROBAR Y ENTENDER

Ejecutar el primer piloto acotado, identificar usos informales y observar datos, calidad y necesidades reales.

Salida: Ficha de un caso + inventario inicial.

DÍAS 16—30

HABILITAR

Formalizar las plataformas útiles, identidad, criterios de clasificación, contratos y DLP probado en los canales reales.

Salida: Catálogo acotado + política y controles.

DÍAS 31—60

AMPLIAR

Extender las tareas que demostraron valor a otras áreas, formar usuarios y corregir fallas de acceso y calidad.

Salida: Resultados de casos adicionales + evidencias.

DÍAS 61—90

ESCALAR

Consolidar revisión ejecutiva y evaluar un agente de autonomía limitada solo si existe justificación.

Salida: Decisión de escalar / ajustar / detener.

Qué debería llegar al directorio

Un tablero que une resultados del negocio con exposición residual.

VALOR	**Tiempo por tarea y calidad del entregable** Comparar grupos o períodos comparables; incluir tiempo de revisión.
ADOPCIÓN	**Uso útil de herramientas y formación** Usuarios activos en casos aprobados; no solo prompts o licencias.
DATOS	**Intentos DLP, excepciones y exposiciones validadas** Distinguir alertas/eventos de incidentes confirmados.
AGENTES	**Acciones bloqueadas, aprobadas y revertidas** Medir privilegios, fallos de ejecución y supervisión.
ECONOMÍA	**Costo real por tarea de calidad aceptada** Contar licencias, API, operación, validación y corrección de errores.

UNA MÉTRICA ÚTIL

Valor neto estimado = beneficio verificable por tarea − costos de plataforma, integración, revisión y errores. No cuente “horas ahorradas” como ingresos sin demostrar cómo se recupera o reinvierte esa capacidad.

Así se presenta un piloto al directorio

SIMULACIÓN DIDÁCTICA · Cifras inventadas para enseñar la lectura, nunca resultados reales.

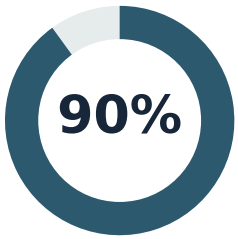
Suponga 20 alertas históricas desidentificadas, evaluadas bajo el mismo criterio antes y después. El tiempo incluye revisión humana; las pruebas de carga indebida usan contenido sintético.

TIEMPO TOTAL POR ALERTA / BASE COMPARABLE

Menor tiempo es favorable si la revisión conserva la calidad.



Variación ilustrativa: 4 minutos menos por alerta (−25%). No son horas convertidas automáticamente en ahorro financiero.



18/20 borradores aceptados al primer pase.

Dos requirieron corrección; no se ocultó el retrabajo.



4/4 cargas prohibidas sintéticas bloqueadas.

Solo evalúa estos cuatro ensayos; no acredita cobertura total.

LECTURA DIRECTIVA / AUTORIZACIÓN CONDICIONADA

Con estos datos hipotéticos se justificaría ampliar el piloto de solo lectura, documentando las dos correcciones y nuevas pruebas. Sin autonomía, sin producción y sin promesa de rentabilidad: para calcular retorno faltan licencias, integración y costos operativos.

Diez preguntas antes de bloquear o desplegar

Checklist de conversación para dirección, CISO, CTO y dueños de procesos.

- [ ] ¿Cuál es el caso de negocio y quién responde por su resultado?
- [ ] ¿Qué clases de datos entrarán, saldrán o quedarán almacenados?
- [ ] ¿La herramienta, el plan y sus funciones fueron evaluados?
- [ ] ¿Se validaron contrato, retención, terceros y ubicación de datos?
- [ ] ¿SSO, MFA, roles y permisos limitan el acceso correctamente?
- [ ] ¿Se prueban DLP, navegador, API y conectores relevantes?
- [ ] ¿La IA solo informa o también puede ejecutar acciones?
- [ ] ¿Hay revisión humana, registro y mecanismo de suspensión?
- [ ] ¿Qué indicador demostrará valor neto sin degradar calidad?
- [ ] ¿Qué hallazgo obligaría a ajustar o retirar la autorización?

NOTA DE CONTEXTO / CHILE

La autorización se fundamenta en el riesgo y en obligaciones aplicables al sector, datos, contrato y entidad concreta. La ley, una norma de referencia y la política interna tienen fuerzas distintas: verifique el texto vigente, el alcance, la evidencia de cumplimiento y las responsabilidades antes de decidir. Véanse los apartados de Chile y sectores regulados. **[16][17][49][50][51]**

Una política competitiva es una política que aprende

Conclusión del autor · criterio de seguridad, gestión y desempeño.

Mi conclusión es sencilla: la prohibición general puede limitar una ruta concreta de exposición, pero no sustituye la disciplina necesaria para gestionar datos, proveedores, personas y agentes. Una política útil debe producir decisiones verificables y capacidad organizacional.

TRES COMPROMISOS QUE DEBERÍAN QUEDAR POR ESCRITO

01

Límite de información

Cada caso especifica qué datos puede procesar, qué debe reducirse y bajo qué entorno contractual y técnico.

02

Límite de capacidad

Cada asistente o agente opera con permisos, conectores, acciones y mecanismos de aprobación acordes al impacto.

03

Prueba de valor

Cada autorización tiene un dueño, una métrica de calidad y costo, y una fecha para decidir si escalar, corregir o retirar.

VISIÓN DE FUTURO / REFLEXIÓN ORIGINAL DE ENRIQUE DE CLERCK

“Cuando la inteligencia artificial ejecute nuestras ideas, liderar será decidir cuáles merecen convertirse en acciones.”

Fuentes y metodología / 1/5

Investigaciones y documentos originales; enlaces activos para contrastar las afirmaciones.

01	**NIST · AI Risk Management Framework (AI RMF 1.0)** airc.nist.gov / ABRIR FUENTE	2023
02	**NIST · Generative AI Profile (NIST AI 600-1)** nist.gov / ABRIR FUENTE	2024
03	**ISO · ISO/IEC 42001, AI Management System** iso.org / ABRIR FUENTE	2023
04	**NBER · Generative AI at Work, w31161** nber.org / ABRIR FUENTE	2023 / revisión
05	**NBER · Shifting Work Patterns with Generative AI, w33795** nber.org / ABRIR FUENTE	2025
06	**NBER · Firm Data on AI, w34836** nber.org / ABRIR FUENTE	2026 / rev. oct.
07	**METR · Experienced Open-Source Developer Productivity** metr.org / ABRIR FUENTE	2025
08	**METR · Actualización del experimento de productividad** metr.org / ABRIR FUENTE	2026
09	**OWASP · LLM Top 10 2026** genai.owasp.org / ABRIR FUENTE	2026
10	**OWASP · Top 10 for Agentic Applications** genai.owasp.org / ABRIR FUENTE	2026
11	**OWASP · AI Agent Security Cheat Sheet** cheatsheetseries.owasp.org / ABRIR FUENTE	2026

Fuentes y metodología / 2/5

Investigaciones y documentos originales; enlaces activos para contrastar las afirmaciones.

12	**Microsoft Learn · Protección de IA externas con Purview** learn.microsoft.com / ABRIR FUENTE	2026
13	**Microsoft Learn · Base segura de datos para Copilot** learn.microsoft.com / ABRIR FUENTE	2026
14	**OpenAI · Privacidad empresarial** openai.com / ABRIR FUENTE	2026
15	**Anthropic · Política de entrenamiento, productos comerciales** privacy.claude.com / ABRIR FUENTE	2026
16	**BCN Chile · Ley 21.719** bcn.cl / ABRIR FUENTE	2024 / 2026
17	**Senado de Chile · Tramitación de postergación** tramitacion.senado.cl / ABRIR FUENTE	2026
18	**OpenAI · Seguridad y privacidad de datos de negocio** openai.com / ABRIR FUENTE	2026
19	**Microsoft Learn · Datos, privacidad y seguridad Copilot** learn.microsoft.com / ABRIR FUENTE	2026
20	**Anthropic · Funciones de Claude Enterprise** support.anthropic.com / ABRIR FUENTE	2026
21	**Anthropic · Controles de retención para Enterprise** privacy.claude.com / ABRIR FUENTE	2026
22	**Google Workspace · Seguridad y privacidad de IA** workspace.google.com / ABRIR FUENTE	2026

Fuentes y metodología / 3/5

Investigaciones y documentos originales; enlaces activos para contrastar las afirmaciones.

23	**Google Workspace · Alcance del DLP para Gemini** knowledge.workspace.google.com / ABRIR FUENTE	2026
24	**Perplexity · Trust Center / preguntas frecuentes** trust.perplexity.ai / ABRIR FUENTE	2026
25	**Perplexity · Enterprise Pro, controles y privacidad** perplexity.ai / ABRIR FUENTE	2026
26	**OpenAI · Análisis de exposición de ChatGPT, marzo 2023** openai.com / ABRIR FUENTE	2023
27	**OpenAI · Incidente de su proveedor Mixpanel** openai.com / ABRIR FUENTE	2025
28	**Microsoft MSRC · CVE-2025-32711 (EchoLeak)** msrc.microsoft.com / ABRIR FUENTE	2025
29	**Tenable Research · Gemini Trifecta, pruebas técnicas** tenable.com / ABRIR FUENTE	2025
30	**Zscaler Research · Exposición de código Claude Code** zscaler.com / ABRIR FUENTE	2026
31	**Vercel · Boletín de incidente, abril 2026** vercel.com / ABRIR FUENTE	2026
32	**OpenAI · Evaluación de agentes e incidente Hugging Face** openai.com / ABRIR FUENTE	2026
33	**xAI · Términos y compromisos empresariales de Grok** x.ai / ABRIR FUENTE	2026

Fuentes y metodología / 4/5

Investigaciones y documentos originales; enlaces activos para contrastar las afirmaciones.

34	**AWS · Seguridad y permisos de Amazon Q Business** docs.aws.amazon.com / ABRIR FUENTE	2026
35	**OpenAI · Controles de datos en ChatGPT personal** help.openai.com / ABRIR FUENTE	2026
36	**Cyberhaven Labs · AI Adoption & Risk Report; muestra 222 firmas** cyberhaven.com / ABRIR FUENTE	2026
37	**Bill Gates · The Age of AI Has Begun; publicación del autor** gatesnotes.com / ABRIR FUENTE	2023
38	**Microsoft · Junta de accionistas; intervención de Nadella** microsoft.com / ABRIR FUENTE	2025
39	**Foto Bill Gates · U.S. HHS, dominio público** commons.wikimedia.org / ABRIR FUENTE	2018
40	**Foto Satya Nadella · LeWeb, licencia CC BY 2.0** commons.wikimedia.org / ABRIR FUENTE	2013
41	**Foto trabajo de oficina · Crew, licencia CC0** commons.wikimedia.org / ABRIR FUENTE	2016
42	**Foto de servidores NERSC · Derrick Coetzee, CC0** commons.wikimedia.org / ABRIR FUENTE	2011
43	**ISO · ISO/IEC 27090, seguridad de sistemas de IA** iso.org / ABRIR FUENTE	2026
44	**ISO · ISO/IEC 23894, gestión de riesgos de IA** iso.org / ABRIR FUENTE	2023

Fuentes y metodología / 5/5

Investigaciones y documentos originales; enlaces activos para contrastar las afirmaciones.

45	**ISO · ISO/IEC 42005, evaluación de impacto de IA** iso.org / ABRIR FUENTE	2025
46	**ISO · ISO/IEC 27001, sistema de gestión de seguridad** iso.org / ABRIR FUENTE	2022
47	**BCN Chile · Ley 19.628, protección de datos personales** bcn.cl / ABRIR FUENTE	1999 / 2026
48	**ANCI · Ley 21.663, Marco de Ciberseguridad** anci.gob.cl / ABRIR FUENTE	2024 / 2026
49	**CMF · RAN 20-10, seguridad de información y ciberseguridad** cmfchile.cl / ABRIR FUENTE	2020 / 2026
50	**BCN Chile · Ley 20.584, información de salud y ficha clínica** bcn.cl / ABRIR FUENTE	2012 / 2026
51	**IEC · IEC 62443-2-1, seguridad de sistemas industriales** webstore.iec.ch / ABRIR FUENTE	2024
52	**Noy y Zhang · Productividad en redacción profesional, Science** doi.org / ABRIR FUENTE	2023
53	**Dell'Acqua et al. · IA en consultoría, Organization Science** doi.org / ABRIR FUENTE	2026

ATRIBUCIÓN Y LECTURA CRÍTICA

Las citas se traducen al español por el autor y pueden contrastarse con el original. Las fotografías se acreditan en sus páginas; los retratos no implican respaldo de las personas a este análisis.